

Ransomware Research

Semir Hot, Harrison Maksimik

February 19, 2024

Contents

1	The Problem	1
2	History of Ransomware	1
2.1	Notable examples	2
3	Ransomware Functionality	2
3.1	Infection vectors	2
3.2	Ransomware implementations	2
3.3	Detection of ransomware	3
4	Impact of Ransomware	3
5	Prevention of Ransomware	4
5.1	Access control	4
5.2	Ransomware awareness	5
6	Mitigation of Ransomware	5
6.1	Backups	6
6.2	Key recovery	6
6.3	Resolve the issue	7
7	Major Cause of Ransomware	7
8	Our Assets	7
8.1	Outside	7
8.2	Inside	8
8.3	Business partners	9
9	Sources	9

1 The Problem

In 2019, Europol determined that ransomware was the leading malware threat for small businesses (Beaman et al., 2021). In the aftermath of the COVID-19 pandemic, the situation has only gotten worse due to the shift to working from home. Additionally, as more assets of our organization are being connected to a network, our organization will see an increase in both the impact of cyber attacks on our business, and our attack surface. Our organization must balance the increase in productivity and convenience with the increase in risk to our assets.

2 History of Ransomware

2005 marked the point at which ransomware shifted from an attack used to gain notoriety among hacking circles, to an extortion tool used by more serious criminals. Throughout time these attacks have changed but still relatively hold the same description from case to case. In the early 2010's, hackers would lock the users out of their machines and would put them at a screen letting them know that their files are encrypted and the only way to get them back was to give them money either through western union or as time has passed thorough crypto currency since it has become "untraceable". In exchange for paying they are able to get all their files back and get their operating system back.

2.1 Notable examples

WannaCry was one of the biggest Ransomware attacks in history. It exploited a vulnerability in the Windows operating system called EternalBlue which was developed by the NSA. The Attack quickly spread through machines and networks and would encrypt files and demand a bitcoin payment in order to release the files back to the user. Hundreds of machines were affected in over 150 countries, leading to massive financial loss and destruction. Another attack that should be highlighted is NotPetya. This attack used the same exploit as WannaCry did, but this one would overwrite the master boot record in order to make system recovery almost impossible if the ransom was not paid. This attack was one of the first attacks that made people consider the use of such malware in a war environment.

3 Ransomware Functionality

3.1 Infection vectors

Ransomware can infect a system through many vectors, which are the paths in which a computer system or network is infected, and becomes vulnerable to either a security threat or malicious software. Infection Vectors can take various forms and manipulate themselves in many ways to allow the attacker to gain access to any system or network they want. Some examples of this are Email attachments; a user can receive an email that looks legitimate with an attachment, and when they open it, it can run scripts or files on the user's system and compromise it. Another example is Drive By Downloads. this is one that is often overlooked and can be stopped very easily. A Drive by download is when a user visits a malicious page and a malicious code is downloaded and then executed automatically. Users are sometimes unaware of this happening, as they visited a site they deemed to be safe. However, their machine may now have been compromised with whatever malware the site installed on their system.

3.2 Ransomware implementations

The goal of ransomware, of course, is to prevent access to data in order to extort money from the organization. To accomplish this, a ransomware developer may choose to encrypt either the system's data files (crypto ransomware), or the files needed for functionality of the system (locker ransomware). In the latter implementation, the system may be difficult to interact with due to display/input functionality, among other things, being compromised. However, if the ransomware chooses to only lock system files, data recovery may be easy for the organization.

Analyzing the implementation of the encryption used in ransomware could also be beneficial for an organization that has been attacked. While modern encryption algorithms are essentially unbreakable, it may be possible to recover the encryption key from a piece of ransomware if the encryption algorithm used is a symmetric algorithm, such as AES (Beaman et al., 2021). An attacker may choose to use this method of encryption due to the significantly higher speed these algorithms show when compared to asymmetric algorithms like RSA. Because of this trade-off, knowledgeable ransomware developers will combine the two types of encryption. In this hybrid approach, the organization's data files are encrypted using a symmetric key generated on the organization's system by the ransomware, then the symmetric key

is encrypted using a key from a public key sent by a command and control server owned by the attacker.

3.3 Detection of ransomware

Some ransomware payloads may take time to be detected; in the case of Cyborg, often considered the first piece of ransomware, the malware used a "logic bomb" which remained dormant until the user rebooted their system 90 times. Following the activation of the logic bomb, the Cyborg malware encrypted the system's data. Depending on the activation condition used, this malware technique could result in a widespread compromise to the organization's systems with little warning.

The primary methods of detecting ransomware can be categorized by either static analysis, or dynamic analysis. In static analysis, potentially malicious software is compared to samples of known ransomware. While this method of malware detection has a low false-positive rate, it cannot detect malware that has been obfuscated by a knowledgeable attacker. Hence, dynamic analysis should also be used to analyze the behavior of a piece of software to find suspicious actions, such as making requests to unknown servers or analyzing network properties in order to propagate. An organization should remain cautious, however, as antivirus software used to automate this analysis process might not detect new pieces of ransomware.

4 Impact of Ransomware

Ransomware is a term that has changed the way we use computers. All over the world people are online using PC's and networks to surf the web. In the process of this, no matter who you are, you are at risk of being attacked by ransomware. With the introduction of Ransomware, people have had to learn how to stay safe online and prevent this attack from affecting them, as usually it leads to data loss if you do not have a backup. Through this, many companies have opened in the hopes of keeping users safe for a price. While Ransomware is not a positive thing, it has generated new industries in the world where people can make money in exchange for keeping people's machines and servers safe and away from the hands of unwanted access. As time goes on, there will be new attacks that we will have to learn to fight and avoid.

Despite the growth in ransomware protection services and tools, organizations still need shoulder responsibility for mitigating and preventing damages from attacks. If an a skilled attacker is determined to compromise an

organization’s security, it is almost inevitable that a breach *will* occur. And even if data can be recovered, the attack can cause significant harm financial and reputational damage, not to mention the loss of productivity hours. The average cost of dealing with a ransomware attack was estimated to be \$1.85 million (Beaman et al., 2021). An organization’s best strategy for dealing with these losses is to have a solid plan for when things go wrong.

5 Prevention of Ransomware

5.1 Access control

Access control should be a major factor in an organization’s ransomware prevention policies. The goal of an access control policy is to restrict access to files to only users who have certain permissions. Many operating systems have access control software out of the box. Linux, for example, ships with SMACK (simplified mandatory access control) built into the kernel. However, third party solutions such as SELinux and AppArmor are often used for more robust controls. However, it’s important to keep the access control policies constantly up-to-date; new policies will eventually need to be created for new business tasks, and old policies will need to be removed when they are no longer needed as a security measure.

The type of access control used could also have a significant impact on how robust of an access control policy an organization can create, as well as the maintainability of the system. While systems like RBAC (role based access control) or access control lists are simple to implement, maintaining these systems can be cumbersome for a security team, which could lead to security risks if the system isn’t constantly kept up to date. This solution also does not scale well as the organization increases in size and complexity. ABAC (attribute based access control) is a more robust solution that allows for extra constraints on access based on environment conditions, but it similarly scales poorly with organization size.

An alternative solution is NGAC (next generation access control), which represents the organization’s resources and structure as a graph (Song et al., 2021). This method of access control is robust enough to fully implement every feature of RBAC while still remaining maintainable in larger organizations. NGAC also provides a feature called Obligations, which acts as an automated response to some access requests. For example, if an administrator has permission to remove a manager from a specific access group, it may be desirable to remove all employees under that manager from the same access group as well. This feature prevents unnecessary permissions from

being kept during a restructure of the access control policy. Additionally, NGAC facilitates easy overlapping of different security policy sets, meaning maintainability is even further enhanced as an organization's policy can be made modular.

5.2 Ransomware awareness

Perhaps the most important defense against ransomware is better awareness among employees of the company. Training employees on best practices for passwords and ways to spot suspicious emails has shown to be an important part of an organization's security plan. Additionally, if employees have access to the organization's data on computers or networks outside of the organization's control, basic training should be given to help users enhance the security of their devices through tools like antivirus software. The employee should also be trained on methods to generate backups of important data.

6 Mitigation of Ransomware

While it would be ideal to entirely prevent ransomware in an organization, this is often not feasible in practice. An organization needs a plan for dealing with ransomware when an infection occurs. Having a well thought-out plan helps speed up the recovery process, and in some cases makes recovery *possible* in the first place. Being slow to recover from a ransomware attack can have a massive financial impact on the organization, even if the data is recovered in the end.

6.1 Backups

The first step to a mitigation strategy should be to ensure that backups are available. The organization must determine how long to keep backups, how often to make them, and where to keep them. Keeping off-site backups is an important part of the recovery process, as some threats may be widespread across an organization's infrastructure. Thus, a common rule of thumb is the 3-2-1 strategy. That is, an organization should have 3 copies of its data (one of which is the production copy), on two different kinds of media (i.e., disk and tape), with one off-site copy. While this strategy may be expensive for a small organization to implement, the price of adhering to this rule should be weighed with the potential losses that could be incurred due to ransomware.

Additionally, alternative solutions to recovering data from solid state drives (SSD) have been explored recently. Because old data on an SSD is not overwritten as soon as it's new data is written, a solution called Flash-Guard was created which slows down the garbage collection process of the SSD (Beaman et al., 2021). This means that the encrypted data being written by the ransomware might not fully remove the data from the victim's SSD as long as the garbage collector is slow enough, making recovery possible. Additionally, some behavior-based detection systems like Amoeba and Redemption have been developed which can terminate the ransomware process before too much data is lost.

6.2 Key recovery

As mentioned previously, it may sometimes be possible to recover encryption keys used by a piece of ransomware if a symmetric key is used. While ransomware that uses a hybrid approach of symmetric and asymmetric cryptography made be more difficult to decrypt for an unprepared organization, some steps could be taken in many cases to assist in easy retrieval of the symmetric key used to encrypt a machines data. Since the symmetric key is usually generated on the victim's machine, an organization should consider keeping backups of keys created on each machine. In this scenario, even if the symmetric key is encrypted using an asymmetric key from a command and control server, a plaintext copy of that symmetric key will still be accessible. Recent software such as Paybreak can be used to help an organization with this process.

6.3 Resolve the issue

After an attack is detected, it's important to immediately work towards finding the source of the intrusion and then cut off that vulnerability from being exploited again. If this is not done in a timely manner, more damage can be done to the organization while the recovery process is happening, and potential forensic evidence could be scrubbed. While recovery needs to happen quickly in order to minimize the already large losses incurred from a ransomware attack, mitigating further damages has to take priority.

7 Major Cause of Ransomware

Unemployment saw a large rise in the wake of the COVID-19 pandemic. During periods of widespread unemployment, cybercrime may become more

frequent as people look for opportunities to ease their hardship. Organizations should be wary of financially difficult times due to potential increase in ransomware and other methods of extortion.

Additionally, with the success shown from recent attacks such as WannaCry and CovidLock, the widespread availability of ransomware services is likely to increase in order to satisfy a growing demand for working extortion tools. These new pieces of malware may take time to be detectable to common antivirus software, meaning organizations will see a period of increased risk of attack. These environmental factors should be considered when balancing the need for information security with other business needs.

8 Our Assets

Our organization relies on two major sources of business: the sale of gasoline outside the building, and the convenience store located inside the building.

8.1 Outside

- Gas Pumps
 - Payment and product selection software
 - Sensors and software to detect full tank
- Gasoline
- Gas tanks (underground)
- Air Compressor
- Oil
- Propane Tanks
- Trash Cans
- Dumpsters
- Ice Cooler

8.2 Inside

- Inventory(Products for sale)
- Point of Sale
 - Passkey/username authentication
 - Requires passkey change every 6 months
- Credit Card readers and machines
 - Processed through Verifone
- Age Restricted goods
 - Lottery ticket system
- goods and items in back stock
- Office
- Commander and servers
- backup servers
- Main PC
- CCTV Cameras
 - 20 cameras in total
 - No blind spots
- DVR hardware/software
 - 6 months of on-site backup footage
 - Remote viewing is possible in close proximity
- Mobile application (Modisoft)
- Network

8.3 Business partners

- Gasoline distributor
- Distributor for store goods
- Distributor for car cleaning supplies
- Contractor for mobile application
- Contractor for network design
- Employees

9 Sources

1. Connolly, L. Y., & Borrion, H. (2020, December). Your Money or Your Business: Decision-Making Processes in Ransomware Attacks. *In ICIS*.
2. Beaman, C., Barkworth, A., Akande, T. D., Hakak, S., & Khan, M. K. (2021). Ransomware: Recent advances, analysis, challenges and future research directions. *Computers & security*, 111, 102490.
3. Song, J., & Barrera, I. (2021, December 21). Why you should choose NGAC as your access control model. *The New Stack*. <https://thenewstack.io/why-you-should-choose-ngac-as-your-access-control-model/>